

Potential buffer overflow in PyArray_NewFromDescr_int of ctors.c #18939

✓ Closed
[#18989](#)

awen-li opened on May 8, 2021 · edited by seberg

Edits ▾ ...

Reproducing code example:

Snippet:

```
PyArray_NewFromDescr_int(..., **int nd**,.....)
{
    .....
    if (descr->subarray) {
        PyObject *ret;
        npy_intp **newdims**[2*NPY_MAXDIMS];
        npy_intp *newstrides = NULL;
        **memcpy** (newdims, dims, nd*sizeof(npy_intp));
        if (strides) {
            newstrides = newdims + NPY_MAXDIMS;
            **memcpy** (newstrides, strides, nd*sizeof(npy_intp));
        }
        .....
    }
}
```

Error message:

When we run our analysis tool on NumPy, a potential buffer-overflow problem was reported. See details below:

File: numpy/core/src/multiarray/ctors.c

Function: PyArray_NewFromDescr_int

Details in [description](#)

Possible call path:

1. array_new -> PyArray_NewFromDescr_int
2. PyArray_Zeros -> PyArray_NewFromDescr_int
3. array_fromfile -> PyArray_FromFile -> PyArray_NewFromDescr_int

NumPy/Python version information:

The main branch of NumPy



eric-wieser on May 8, 2021

Member ...

I think this is probably safe at the call sites, but adding an assert to `PyArray_NewFromDescr_int` would probably be a good idea just to verify that



awen-li on May 10, 2021

Author ...

Thanks for your reply.
As the variable "nd" may come from an external module or language component (Python), an assert or boundary check is necessary as your suggestion.



eric-wieser on May 10, 2021

Member ...

Yes you're right, `PyArray_Zeros` is an API function, and does not perform any checking of `nd` before deferring to `PyArray_NewFromDescr_int` :

[numpy/numpy/core/src/multiarray/ctors.c](#)

Lines 2819 to 2828 in [623bc1f](#)

```
2819     NPY_NO_EXPORT PyObject *
2820     PyArray_Zeros(int nd, npy_intp const *dims, PyArray_Descr *type, int is_f_order)
2821     {
2822         PyArrayObject *ret;
2823
2824         if (!type) {
2825             type = PyArray_DescrFromType(NPY_DEFAULT_TYPE);
2826         }
2827
2828         ret = (PyArrayObject *)PyArray_NewFromDescr_int(
```



seberg on May 10, 2021

Member ...

It might be a bit hard to abuse, but the check for `nd` should indeed be moved up here to be on the safe side.



seberg added **00 - Bug** **good first issue** on May 10, 2021



yetanothercheer added a commit that references this issue on May 11, 2021

BUG: fix potential buffer overflow([numpy#18939](#))

16f7824



yetanothercheer mentioned this on May 11, 2021

[BUG: fix potential buffer overflow\(#18939\) #18989](#)

-  **charris** closed this as completed in [#18989](#) on May 12, 2021
-  **charris** added a commit that references this issue on May 12, 2021
Merge pull request [#18989](#) from yetanothercheer/[gh-18939](#)-potential_buf. ... Verified ae317fd
-  **github-actions** mentioned this on Jan 7, 2022
[Security Alert dauidspek/kubeflownotebooks#316](#)
-  **rasabot** mentioned this on Jan 8, 2022
[Security Alert RasaHQ/rasa#8638](#)
-  **tkilias** added a commit that references this issue on Jan 11, 2022
BUG: fix potential buffer overflow([numpy#18939](#)) 9f1c1e0
-  **jamie256** mentioned this on Jan 13, 2022
[Update numpy to version 1.21 or later in poetry.lock file whylabs/whylogs#414](#)
-  **seberg** added a commit that references this issue on Jan 13, 2022
Merge pull request [#20801](#) from tkilias/backport-18989 ... Verified fdcb2e4
-  **trimeta** mentioned this on Jan 13, 2022
[Accelerate release of 0.55 to no longer depend on versions of numpy with buffer overflow numba/numba#7731](#)
-  **jfResearchEng** mentioned this on Apr 3, 2022
[Update Numpy to >= 1.21 facebookresearch/labgraph#70](#)

[Sign up for free](#) to join this conversation on GitHub. Already have an account? [Sign in to comment](#)

Assignees

No one assigned

Labels

00 - Bug

Type

No type

Projects

No projects

Milestone

No milestone

Relationships

None yet

Development

 Code with agent mode



 **BUG: fix potential buffer overflow(#18939)**
numpy/numpy

Participants

